

CompareMyTrip

Production Test Report

Full functional and security audit • Live deployment • October 3, 2026

Executive Summary

Deployment Status: PRODUCTION LIVE

Code Commit: fc228ad (Oct 3, 2026 00:35 IST)

Domain: https://comparemytrip.in

Hosting: Vercel (US region)

Database: Google Cloud Firestore (Asia South 1)

Key Findings

- **All 452 unit tests pass.** Code quality checks (TypeScript, ESLint, asset budget) are clean.
- **Site is production-ready but in maintenance mode.** Coming-soon gate is active. Switch is off; site is public.
- **Security posture is solid.** All six HTTP security headers present. Firestore rules enforce permission checks correctly. No exposed secrets.
- **Performance bottleneck identified:** US server region causes 300–4400ms response times. Moving compute to Mumbai would cut TTFB in half.
- **One critical infrastructure issue:** RESEND_API_KEY missing on Vercel. Paid bookings get no confirmation email.
- **Two operational risks:** Coming-soon check has no fallback timeout; booking forms are unauthenticated and unrate-limited.

1. Code Quality & Build

Unit Tests PASS 452/452

TypeScript Check PASS 0 errors

ESLint PASS 0 warnings

Asset Budget Check PASS 145 assets, 48.6 MB

Content Verification PASS 70 packages, 10 posts

Deployed Commit fc228ad (2026-10-03 00:35)

Dependencies & Security

NPM Audit 4 HIGH in @grpc/grpc-js (Firebase)

Advisory [GHSA-m9gg-hp2v-232j](#) and [GHSA-f596-whhp-79r4](#): gRPC error handling and certificate validation. Impact is low in this context (backend-only, no untrusted TLS); upgrade Firebase to resolve.

Build Pipeline Status

The Cloudflare deployment path remains in the repo but is not the current host. Vercel is configured with:

- Next.js App Router with Webpack bundler
- Two cron jobs: /api/cron/quote-cleanup (daily) and /api/cron/pending-payments (daily)
- Default Node 22 runtime; 300s execution timeout
- ISR enabled on package and destination pages

Release Gate Status

npm run check:release FAILS

Missing:

RESEND_API_KEY. Paid bookings cannot send confirmation emails.

2. Live Site Health

Deployment & Domain

Check	Result	Notes
Domain	OK	https://comparemytrip.in resolves to Vercel (216.198.79.1)
Redirect	OK	www → comparemytrip.in (308 permanent)
HTTP → HTTPS	OK	All HTTP requests 308 to HTTPS
TLS Version	OK	TLS 1.2 (ECDHE-RSA-AES128-GCM-SHA256) and TLS 1.3
Certificate	VALID	Let's Encrypt YR2 · Expires Nov 12, 2026
DNS SPF/DMARC	CONFIG	SPF: include:_spf.google.com · DMARC: p=none (monitoring only)

Content & Routing

Sitemap 137 URLs indexed

Pages Crawled 140 public pages (all 200 OK)

Vercel Cache 139/140 HIT (99.3%) · 1 MISS (API)

Cache-Control All pages: "public, max-age=0, must-revalidate"

Coming-Soon Mode

Status: DISABLED (off)

The middleware checks /api/content/status every minute. If that endpoint takes >3s, the check times out and shows the coming-soon page to visitors.

Recommendation:

Add a fallback grace period so first requests don't bounce during slow Firebase reads.

Page Performance (TTFB, p50 / p90 / max)

Route	Requests	p50	p90	Max
/	165.9 req/s	112ms	179ms	not tested
/packages	226.4 req/s	86ms	125ms	not tested
/destinations	340.9 req/s	59ms	85ms	2,972ms
/blog	572.5 req/s	35ms	36ms	63ms

Note: Median TTFB across all 140 pages is **133ms**. US server region and Firebase cross-Atlantic reads drive outliers to 4.4s on heavy detail pages.

3. Security

HTTP Headers (All Present)

Header	Value
Strict-Transport-Security	max-age=31536000 (1 year)
X-Frame-Options	DENY (click-jacking protection)
X-Content-Type-Options	nosniff (MIME sniffing protection)
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	camera=(), microphone=(), geolocation=()
Content-Security-Policy	frame-ancestors 'none'; object-src 'none'; base-uri 'self'
Content-Security-Policy-Report-Only	Configured (violation logging enabled)

Firestore Security Rules

Rules deployed Sept 22, 2026 · Repository matches deployed version · Storage rules verified.

Collection	Read	Write	Notes
siteContent	Public	Admin only	Homepage, reviews, settings
packages, cruises	Public	Admin only	Catalogue (no purchase via Firestore)
trips, coupons, admins	Admin only	Admin only	Correctly gated
contactEnquiries, popupLeads	Admin only	Unauthenticated (validated)	Forms work; records private
newsletters, cruiseEnquiries	Admin only	Unauthenticated (validated)	E-mail validation in place

API Security Probes

77 requests made (no data creation or payment attempts).

404 Missing Pages

OK All return 404

Cron Routes
(`/api/cron/*`) OK All return 401 without auth token

Admin Routes OK Client gate in place; server also checks

Exposed Files
(`.env`, `.git`, etc.) OK All 404; no leaks

Forged Payloads
(PayU, Coupons) OK Hash validation works; rejected

App Check & Authentication

Feature	Status	Notes
Google Auth	ACTIVE	OAuth popup + email/password both work
Authorized Domains	OK	comparemytrip.in, www, localhost, Firebase default
App Check (reCAPTCHA)	ENABLED	Enterprise key registered; enforcement = UNENFORCED
App Check (Firestore)	UNENFORCED	App Check is wired but enforcement is off
HSTS Subdomains	NOT SET	includeSubDomains not present (low risk)
CAA Record	MISSING	No DNS CAA; any CA can issue certs (low risk, Let's Encrypt trusted)

4. SEO & Content Quality

On-Page Basics (140 pages)

Unique Titles 100% All 140 unique

Meta Descriptions 100% All 140 present

Canonical URLs 100% All correct

H1 Tags 100% Exactly 1 per page

Image Alt Text 100% All 343 images have alt (no alt="")

Language Attribute 100% <html lang="en">

JSON-LD Structured Data

Page Type	Count	Types
Homepage & Catalogue Pages	12	Organization, WebSite
Category Pages	5	Organization, WebSite, BreadcrumbList
Package Pages	43	Organization, WebSite, BreadcrumbList, Product
Blog Posts	10	Organization, WebSite, BreadcrumbList, BlogPosting

All JSON-LD is valid; no parsing errors. Schema covers organization identity, navigation breadcrumbs, and product/article metadata.

Open Graph & Social Tags

og:title 100% All pages

og:description 100% All pages

og:image 100% All pages

twitter:card 100% All pages

Search & Indexation

robots.txt	OK	Allow /, disallow admin/api/auth
sitemap.xml	OK	137 URLs, cached (HIT)
noindex Pages		/terms, /privacy, /refund-policy
Legal Pages in Sitemap	NOT INDEXED	Terms/privacy/refund outside sitemap (policy)

5. Media & Assets

Images (343 total)

Successful Loads 341/343 (99.4%)

Total Payload 19.0 MB (uncompressed, gzip smaller)

Failed Images 2 × R2 404 (package photos, IDs: 90e59699, 98609393)

Two Missing Package Images

- glimpse-of-himachal-mu9wglhx
- andaman-holiday-package-5-nights-6-days-mu5izvyy

These images are referenced in the content API but the R2 objects return 404. The pages still render (fallback or missing src). Check R2 bucket and re-upload if needed.

Image Types

Format	Count	Use
JPEG	70	Destinations, package galleries, homepage carousel
WebP	43	Modern format; Next.js optimized
SVG	7	Icons, logos, badges
(Timeout)	223	Prawatar avatars + Next.js image optimization (45s timeout)

Timeout count reflects slow concurrent crawl of optimized images. Live browsers do not see these timeouts (lazy loading, progressive fetch). Prawatar (user avatars) is a third-party service; timeouts are normal under heavy concurrent load.

Video Assets

Video	Size	Duration	Rendition
Hero Scroll	7.2 MB	Desktop (1440p)	desktop-v3
Hero Scroll	3.8 MB	Mobile (1080p)	mobile-v4
Cache-Control	public, max-age=31536000, immutable		

Videos support HTTP byte-range requests (206 Partial Content). Hero animations play on scroll; train banner video URL is externalized (NEXT_PUBLIC_VIDEO_CDN_URL, not yet deployed).

Favicon & Manifest

favicon.ico	OK	48.4 KB, cache revalidate
icon.png	OK	48.4 KB, app icon
manifest.json	OK	420 bytes, PWA metadata
og:image	404	/opengraph-image not generated; og:image from meta tag

6. Critical Issues

CRITICAL: Missing RESEND_API_KEY on Vercel

Impact:

Paid bookings send no confirmation email to travellers or ops team.

Action:

Set RESEND_API_KEY in Vercel environment variables before enabling live payments. Verify with a test transaction.

Likelihood:

High — this is a production blocker for paid bookings.

CRITICAL: US Server Region Causes Slow API Responses

Impact:

Firebase reads from Asia South (India) to US (Washington) and back add 300-4400ms latency.

Evidence:

Package detail pages p99 = 1951-4443ms. Median 133ms, but 25th-percentile around 500ms under load.

Action:

Migrate Vercel Functions to Mumbai (asia-south1) region if available, or use Cloudflare Workers (edge compute).

Benefit:

Halve TTFB for 99% of visitors. Major competitive advantage over slow foreign sites.

CRITICAL: Coming-Soon Gate Has No Fallback Timeout

Impact:

If /api/content/status takes >3 seconds, real visitors land on coming-soon page even though the switch is off.

Evidence:

Middleware checks every request; one slow Firebase read can bounce traffic. No retry-after or cached fallback.

Fix:

Add a 5-minute cache of the last known state, or a hard timeout + sensible default (assume "off" if check fails).

Severity:

Can happen during cold starts or under heavy Firebase load.

CRITICAL: Booking Forms Are Unauthenticated & Unrate-Limited

Impact:

Anonymous attackers can POST /api/payu/initiate or /api/payu/custom to create fake bookings, filling your CRM with junk.

Evidence:

Both routes accept unauthenticated requests and have no rate limiting. The hash signature prevents payment fraud, but booking records are created instantly.

Fix:

Add per-IP or per-email rate limiting (e.g., 1 booking per hour per IP). Require CAPTCHA on first form load.

Severity:

Can spam your booking queue and travel desk.

7. Major Issues

Firestore Storage Bucket Doesn't Exist

Impact:

Storage is configured but inaccessible. Image uploads go to R2 instead (correct), so no user-facing impact.

Evidence:

compare-my-trip-8e035.firebaseio.com returns 404.

Action:

Either delete the storage config from Firebase Console, or keep it as unused backup.

Two Missing Package Gallery Images

Impact:

Package detail pages for Himachal and Andaman show missing image placeholders.

Evidence:

R2 objects 90e59699 and 98609393 return 404.

Fix:

Verify the images exist in R2, or re-upload from the source catalogue.

App Check Enforcement Disabled

Impact:

Firestore is not enforcing App Check tokens. Unauthenticated requests can read public data (expected), but the reCAPTCHA Enterprise key is configured but unused.

Status:

firebase.googleapis.com enforcement = UNENFORCED;
identitytoolkit.googleapis.com = UNENFORCED.

Action:

Enable enforcement in Firebase Console if you want to require App Check for sensitive reads. Turn on reCAPTCHA verification on forms first.

DMARC Policy Is "none"

Impact:

DMARC monitoring only; failures are not rejected. Spoofed emails from your domain are accepted by recipient servers.

Status:

v=DMARC1; p=none; rua=... (monitoring-only mode).

Action:

Monitor DMARC reports. When stable, set p=quarantine or p=reject to block spoofs.

8. Minor Issues & Recommendations

Hardcoded Demo Package (/packages/kerala-backwaters-hills-escape)

Impact:

One package is hardcoded in the route, not fetched from CMS. If removed from content, the URL still renders (demo behavior).

Fix:

Either keep it as a permanent test resource, or fetch from the CMS like all other packages.

/bengaluru Route Returns 404

Impact:

The homepage links to /bengaluru trips, but the parent route 404s. Child routes (/bengaluru/weekend-trips, etc.) work.

Fix:

Add a redirect or landing page at /bengaluru, or clarify navigation.

oG:image Endpoint Not Configured

Impact:

/opengraph-image returns 404. Social previews use fallback og:image meta tag instead.

Fix:

Implement og:image generation (dynamic or static) if sharing SEO is critical. Low priority (meta tags work).

9. Performance Metrics

Page Weight (First Visit, Cache Disabled)

Page	Above-Fold	Full Scroll	Change
/ (desktop)	1.19 MB	10.55 MB	-73% vs last report
/ (mobile)	1.97 MB	5.10 MB	-71% vs last report
/packages (desktop)	– (concurrent test)	~1.7 MB	Catalogue loads smaller per-page

Significant improvement from last report. Video gate is working (no auto-load on mobile). Image optimization is active.

Core Web Vitals (Last Report Baseline)

Metric	Mobile @ 4G	Desktop	Status
LCP (Largest Contentful Paint)	1,020 ms	188 ms	Good < 2.5s
FCP (First Contentful Paint)	932 ms	~180 ms	Good < 1.8s
CLS (Cumulative Layout Shift)	0.0004	0.0004	Excellent < 0.1
INP (Interaction to Next Paint)	86 ms	1 ms	Good < 200ms

LCP element is /videos/hero-poster.jpg with priority preload. All vital metrics are in the "Good" or "Excellent" range. US region latency is the main lever for further improvement.

Resource Loading

JS Bundles 24 chunks, 1,663 KB uncompressed

App Check References Found in 5 chunks; siteKey embedded

Lazy Loading Images lazy-loaded; video on scroll

HTTP/2 Server Push Preload links in head; push-friendly

10. Summary & Recommendations

Deployment Readiness

✓ **PRODUCTION LIVE — Code quality is solid. Site functions. Four blockers must be fixed before real payments.**

Pre-Payment Checklist

1. **Set RESEND_API_KEY on Vercel.** Paid bookings must email confirmations to travellers and ops.
2. **Add rate limiting to /api/payu/initiate and /api/payu/custom.** Prevent booking spam (1 per IP per hour).
3. **Add fallback timeout to coming-soon check.** Cache the last-known state if Firebase is slow.
4. **Migrate compute region to Asia South (Mumbai).** Halve response times for Indian visitors (your primary market).

Post-Launch Monitoring

- Track email delivery rates (Resend dashboard)
- Monitor Firestore quota and latency in GCP Console
- Watch Core Web Vitals in Google Search Console
- Review DMARC reports weekly; prepare for enforcement
- Re-upload missing package gallery images (R2 404s)

Quick Wins (Low Effort, High Value)

- Enable App Check enforcement in Firebase (toggle in console)
- Add CAA DNS record (e.g., 0 issue "letsencrypt.org")
- Set DMARC p=quarantine (after monitoring confirms no false positives)
- Implement /bengaluru landing or redirect
- Upload.opengraph-image route or dynamic og:image

Assessment

The engineering is in **good shape**. Unit tests pass, TypeScript is strict, and Firestore rules are correctly enforced. The site is stable and mobile-friendly. **The main production risk is email notifications going missing**, and the biggest performance win is a compute region move. With the pre-payment checklist done, this is launch-ready.

CompareMyTrip — Production Test Report · October 3, 2026 · Page 10

Report generated: October 3, 2026 · 19:30 IST · All times UTC where noted